

# purdue-l2-area-supervisory brief

---

## Purdue Area Supervisory Control (L2) — Cross-Vendor Threat & Detection Brief

---

**Scope:** Purdue Level 2 (Area Supervisory Control) is the HMI and operator-workstation tier that sits between L3 site operations / SCADA and L1 basic control (PLCs/RTUs). It is where shift operators see process state and issue manual commands. Devices in scope include dedicated HMI panels (Siemens Comfort/Basic/Unified, Rockwell PanelView Plus 6/7 and PanelView 800, Schneider Magelis HMIGTO/GTU/GTW/STO), HMI runtime software on industrial PCs (Siemens WinCC Runtime Advanced/Professional, Rockwell FactoryTalk View ME, Schneider EcoStruxure Operator Terminal Expert / Vijeo Designer, AVEVA InTouch), and the thin-client / IPC hardware that hosts these runtimes. L2 talks **down** to L1 over Modbus TCP (TCP/502), EtherNet/IP CIP (TCP/44818, UDP/2222), OPC UA/DA, and Siemens S7Comm (TCP/102) to read tags and issue setpoints, and **up** to L3 via the SCADA data channel (FactoryTalk Linx Gateway, Siemens WinCC Server, OPC tunneling). L2's defining property for an attacker is that it controls **what operators see** — making it the primary surface for **Manipulation of View (T0832)** to mask physical actions performed at L1.

### Architecture grouping (organized by ROLE within this layer, not by vendor)

| Class (role)                      | Products (cross-vendor)                                                                                                                                                | Stack (RTOS/protocol/OS)                                                                                  | Catalog depth           |
|-----------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------|-------------------------|
| Dedicated HMI panel (touchscreen) | Siemens Comfort TP700/900/1200/1500/1900, Basic KTP400/700/900/1200, Unified Comfort; Rockwell PanelView Plus 6/7, PanelView 800; Schneider Magelis HMIGTO/GTU/GTW/STO | Windows CE / Windows Embedded Compact / Linux variants; VNC, RDP, HTTP, FTP, SMB, CIP, S7Comm, Modbus TCP | research only           |
| HMI runtime on Windows IPC        | Siemens WinCC Runtime Advanced + Runtime Professional; Rockwell FactoryTalk View ME Station and FactoryTalk View SE; Schneider Vijeo Designer Runtime; AVEVA InTouch   | Windows 10/11 IoT Enterprise, Windows Server 2019/2022; OPC UA, CIP, S7Comm, Modbus TCP                   | partial (vendor briefs) |
| Mobile / wireless HMI             | Siemens Mobile Panel KTP; third-party tablet HMIs with FactoryTalk ViewPoint                                                                                           | Embedded Linux / Android; WPA2, HTTPS, RDP                                                                | research only           |

| Class (role)                       | Products (cross-vendor)                                                                                                                                                                             | Stack (RTOS/protocol/OS)               | Catalog depth |
|------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------|---------------|
| Thin-client / operator workstation | Generic industrial PCs running WinCC RT / FT View ME / InTouch under kiosk shell                                                                                                                    | Windows 10/11 IoT, Citrix/RDP terminal | research only |
| Local project & runtime data       | FactoryTalk View ME <code>.mer</code> runtime archives, Siemens WinCC <code>.fwx</code> / archives, Schneider Vijeo <code>.vdz</code> / EcoStruxure OTE projects, AVEVA InTouch <code>.aaPKG</code> | Local NTFS, ZIP-wrapped XML/binary     | research only |

## Group 1 — Dedicated HMI panel (touchscreen)

**Direct attack surface** — VNC (default port 5900, often no auth or shared password), built-in web server (HTTP 80 / HTTPS 443), FTP 21 (project upload/download), CIP (TCP/44818, UDP/2222) or S7Comm (TCP/102) or Modbus TCP (TCP/502) toward L1, SMB/CIFS shared project folders, and on Siemens Unified panels a Node-RED / web-services API. Many panels ship with these services **enabled by default** out of the box.

### Confirmed CVEs across vendors:

| CVE                                                               | CVSS   | Vendor    | Product                                               | Vector                                                                      |
|-------------------------------------------------------------------|--------|-----------|-------------------------------------------------------|-----------------------------------------------------------------------------|
| <a href="#">CVE-2023-2071</a>                                     | 9.8    | Rockwell  | FactoryTalk View ME / PanelView Plus                  | Unauthenticated RCE via crafted packet ( <a href="#">ICSA-23-180-04</a> )   |
| <a href="#">CVE-2023-29464</a>                                    | 8.2    | Rockwell  | PanelView Plus                                        | Unauth info disclosure + DoS ( <a href="#">ICSA-23-194-04</a> )             |
| <a href="#">CVE-2023-3025</a>                                     | 7.5    | Schneider | EcoStruxure Operator Terminal Expert / Vijeo Designer | Plaintext credential storage in project ( <a href="#">Schneider PSIRT</a> ) |
| <a href="#">CVE-2023-3026</a>                                     | 7.8    | Schneider | EcoStruxure Operator Terminal Expert                  | Local privilege escalation via project import                               |
| Siemens HMI session/auth family (see <a href="#">SSA-264815</a> ) | varies | Siemens   | SIMATIC WinCC / Comfort Panels                        | Insufficient session validation / auth bypass on panel web stack            |

**Top attack vector (MITRE ATT&CK ICS):** [T0866 Exploitation of Remote Services](#) — unauth network exploits land code on the panel itself, which then becomes a permanent foothold inside the cell network. [T0812 Default Credentials](#) is a close second on panels shipped with factory VNC/web passwords.

## Group 2 — HMI runtime on Windows IPC

---

**Direct attack surface** — FactoryTalk Services Platform / RNA on TCP 1330, 1331, 4241; WinCC Runtime SQL backend (TCP/1433); InTouch Window Viewer hosting NetDDE/SuiteLink (TCP/5413); RDP 3389 for remote operator access; OPC UA 4840 northbound and southbound. The Windows host itself adds SMB, WinRM, and any AV / EDR-bypassable surface.

### Confirmed CVEs across vendors:

| CVE                                                                                  | CVSS   | Vendor   | Product                                     | Vector                                                                      |
|--------------------------------------------------------------------------------------|--------|----------|---------------------------------------------|-----------------------------------------------------------------------------|
| <a href="#">CVE-2024-21915</a>                                                       | 9.8    | Rockwell | FactoryTalk Services Platform               | Privilege escalation on shared FTSP host ( <a href="#">ICSA-24-018-01</a> ) |
| <a href="#">CVE-2024-37368</a>                                                       | 9.8    | Rockwell | FactoryTalk View SE                         | Unauth RCE via deserialization ( <a href="#">ICSA-24-191-01</a> )           |
| Siemens WinCC Runtime project-import family ( <a href="#">Siemens ProductCERT</a> )  | varies | Siemens  | SIMATIC WinCC Runtime Advanced/Professional | Local code execution via crafted project file                               |
| Siemens WinCC Runtime Professional auth-bypass family ( <a href="#">SSA-264815</a> ) | varies | Siemens  | WinCC Runtime Professional                  | Insufficient session validation / memory disclosure                         |
| AVEVA InTouch Access Anywhere / Edge advisories ( <a href="#">AVEVA Security</a> )   | varies | AVEVA    | InTouch Access Anywhere / Edge              | Unauthenticated remote vulnerabilities on the web gateway                   |
| <a href="#">CVE-2024-3982</a>                                                        | 9.3    | Rockwell | FactoryTalk View ME                         | Hardcoded service credential ( <a href="#">ICSA-24-165-01</a> )             |

**Top attack vector (MITRE ATT&CK ICS):** [T0866 Exploitation of Remote Services](#) lands code; the runtime daemon typically runs as SYSTEM/LocalSystem and becomes the foothold for tag-write authority into L1.

## Group 3 — Mobile / wireless HMI

---

**Direct attack surface** — Wi-Fi (frequently WPA2-PSK with shared cell password), web HMI hosted on the panel, optional pass-through credentials to the same OPC/CIP/S7Comm tag space as a fixed panel. Public CVE depth is lower, but the Siemens WinCC session-validation family ([SSA-264815](#)) applies equally to Siemens Mobile Panel KTP runtimes.

**Top attack vector:** [T0830 Adversary-in-the-Middle](#) — wireless link is the cheapest MitM position in the plant. [T0883 Internet Accessible Device](#) becomes relevant when tablet HMIs are exposed via a cellular/4G fallback.

## Group 4 — Thin-client / operator workstation

---

**Direct attack surface** — Kiosk-shell escape (sticky-keys, accessibility-feature swap, browser shell breakout from a "browser-only" HMI policy), RDP/Citrix session hijack, USB device-control bypass, removable-media autorun on engineering USB sticks (Stuxnet-class). The Windows host generally has full L1 reachability because the kiosk **must** be able to write tags.

**Top attack vector:** [T0859 Valid Accounts](#) — shared operator account is the norm in 24/7 control rooms; password is often on a sticker on the panel.

## Group 5 — Local project & runtime data

---

**Direct attack surface** — Project files ( `.mer` , `.fwx` , `.vdz` , `.aaPKG` ) are ZIP/CAB-wrapped XML+binary; importing a malicious project on a development workstation is the **Evil PLC** pattern applied to HMI: open the file in the editor, get code execution on the engineer's host. CVE-2023-3025 / CVE-2023-3026 (Schneider) directly fall in this class, as does the Siemens WinCC project-import family covered under [Siemens ProductCERT](#).

**Top attack vector:** [T0843 Program Download](#) — pushing a tampered runtime archive replaces what the operator sees without touching L1 firmware.

## Logging matrix (highest priority for this layer)

---

| # | Source                                     | Event                                      | What it catches                               | MITRE ATT&CK ICS      |
|---|--------------------------------------------|--------------------------------------------|-----------------------------------------------|-----------------------|
| 1 | Windows Security (HMI IPC)                 | 4624 type 3/10 from non-engineering subnet | Remote logon to HMI host from non-EWS network | <a href="#">T0859</a> |
| 2 | FactoryTalk Diagnostics / WinCC AuditTrail | Tag write outside scheduled window         | Off-shift setpoint change, masked HMI view    | <a href="#">T0831</a> |

| # | Source                                  | Event                                                                                                                                                                    | What it catches                               | MITRE ATT&CK ICS      |
|---|-----------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------|-----------------------|
| 3 | Sysmon Event 1 (HMI IPC)                | <code>wincc*.exe</code> / <code>FTView*.exe</code> / <code>view.exe</code><br>spawning <code>cmd.exe</code> , <code>powershell.exe</code> ,<br><code>rundll32.exe</code> | Runtime-process living-off-the-land           | <a href="#">T0866</a> |
| 4 | Network sensor (Zeek/Dracos/Claroty)    | VNC (5900) or RDP (3389) into HMI from outside engineering VLAN                                                                                                          | External operator-console access              | <a href="#">T0822</a> |
| 5 | Network sensor                          | New CIP/S7Comm/Modbus TCP client IP writing tags that has never written before                                                                                           | First-seen tag-writer                         | <a href="#">T0855</a> |
| 6 | FT View ME / WinCC project file watcher | Runtime archive ( <code>.mer</code> / <code>.fwx</code> ) replaced or hash-changed outside change-window                                                                 | Tampered HMI graphics (view forgery)          | <a href="#">T0832</a> |
| 7 | Sysmon Event 11/15                      | New executable dropped under FT View / WinCC / InTouch install dir                                                                                                       | Persistence inside HMI runtime tree           | <a href="#">T0820</a> |
| 8 | OPC UA server log (L1 PLC)              | Tag-write source = HMI IP but the HMI screen log shows no operator action                                                                                                | View/control desync — classic Stuxnet pattern | <a href="#">T0832</a> |

**Secondary:** WinCC AuditTrail tamper-detect events, FactoryTalk Diagnostics security-channel events, Schneider Vijeo audit logs, panel firmware-version drift telemetry, USB-device-control events on operator IPCs, kiosk-shell-escape detections (sticky-keys, `sethc.exe` modification), DNS queries to the Internet from a panel IP (panels should never resolve external names).

## Cross-layer pivots

- L2 HMI → L1 PLC via authenticated tag write (the textbook pivot).** Attacker lands on an HMI runtime (e.g. CVE-2023-2071 against PanelView Plus, or CVE-2024-37368 against FT View SE), inherits the trusted CIP/S7Comm/OPC connection to the PLC, and issues setpoint changes or [T0858 Change Operating Mode](#) commands. No PLC-side exploit is needed — the HMI is *already* authorized. Pair with [T0833 Modify Control Logic](#) if the HMI runtime also hosts the project-download path.
- L2 → L3 SCADA via the data channel.** Compromised WinCC Runtime Professional or FT View SE node poisons the upward feed (OPC UA, FactoryTalk Linx Gateway, WinCC server tunnel) into the L3 historian and operator graphics. Operators at the control center see falsified tags; this is [T0832 Manipulation of View](#) propagated one layer up and was a core element of both Stuxnet (faked centrifuge readings) and Industroyer's substation-display masking.

3. **L2 HMI as Manipulation-of-View deception target.** Attacker does **not** modify L1 logic. Instead, after foothold via CVE-2024-21915 (FTSP priv-esc) the attacker hooks the HMI rendering layer so screen values are decoupled from actual PLC values. Physical actions taken via a second channel (engineering workstation at L3, or direct CIP from a compromised IT host) go unseen until the next physical inspection. This is the highest-impact, lowest-noise option for a sophisticated actor and is what TRITON-class operators have been observed staging.
4. **L2 → adjacent L2 lateral via shared FactoryTalk Services Platform.** FTSP and WinCC server farms typically share a single Windows domain or workgroup with shared local-admin credentials. A single panel compromise (Group 1) → IPC compromise (Group 2) → FTSP credential dump → silent fanout to every other HMI runtime in the area. Pivot uses [T0884 Connection Proxy](#) and [T0859 Valid Accounts](#).

## Sources

---

- CISA ICS-CERT advisories index — <https://www.cisa.gov/news-events/cybersecurity-advisories/ics-advisories>
- ICSA-23-180-04 — Rockwell FactoryTalk View ME
- ICSA-23-194-04 — Rockwell PanelView Plus
- ICSA-24-018-01 — Rockwell FactoryTalk Services Platform
- ICSA-24-165-01 — Rockwell FactoryTalk View ME
- ICSA-24-191-01 — Rockwell FactoryTalk View SE
- Siemens ProductCERT — <https://cert-portal.siemens.com/productcert/html/>
- SSA-264815 — Siemens SIMATIC WinCC
- Schneider Electric PSIRT / Security Notifications — <https://www.se.com/ww/en/work/support/cybersecurity/security-notifications.jsp>
- Rockwell Automation Trust Center — <https://www.rockwellautomation.com/en-us/trust-center.html>
- AVEVA Security Advisories — <https://www.aveva.com/en/support-and-success/cyber-security-updates/>
- AA24-038A Volt Typhoon (CISA, Feb 2024) — <https://www.cisa.gov/news-events/cybersecurity-advisories/aa24-038a>
- Claroty Team82 — Evil PLC Attack research — <https://claroty.com/team82/research/evil-plc-attack-weaponizing-plcs>
- Armis TLStorm research — <https://www.armis.com/research/tlstorm/>
- Dragos — Industroyer2 analysis — <https://www.dragos.com/blog/industry-news/industroyer2-analysis/>
- Forescout / Vedere Labs OT:ICEFALL — <https://www.forescout.com/research-labs/ot-icefall/>
- MITRE ATT&CK for ICS — Manipulation of View (T0832) — <https://attack.mitre.org/techniques/T0832/>

- MITRE ATT&CK for ICS — Unauthorized Command Message (T0855) — <https://attack.mitre.org/techniques/T0855/>
- MITRE ATT&CK for ICS — Exploitation of Remote Services (T0866) — <https://attack.mitre.org/techniques/T0866/>
- Purdue Model / ISA-95 — <https://www.isa.org/standards-and-publications/isa-standards/isa-standards-committees/isa95>
- IEC 62443 series (industrial network and system security) — <https://www.iec.ch/cyber-security>